# MỤC LỤC

**DANH MỤC TỪ VIẾT TẮT** ..... **3**
**CHƯƠNG 1: TỔNG QUAN ĐỒ ÁN** ..... **4**
**1.1. Mục tiêu và phạm vi** ..... 4
**1.2. Kiến trúc hệ thống** ..... 4
**1.3. Công nghệ và thư viện sử dụng** ..... 4
**1.4. Cấu trúc thư mục** ..... 5
**1.5. Định hướng thiết kế giao diện** ..... 6
**CHƯƠNG 2: HƯỚNG DẪN CÀI ĐẶT VÀ CHẠY** ..... **7**
**2.1. Yêu cầu môi trường** ..... 7
**2.2. Lấy mã nguồn và cài thư viện** ..... 7
**2.3. Cấu hình file .env** ..... 7
**2.4. Chạy hệ thống** ..... 8
**2.5. Kiểm tra máy chủ đã hoạt động** ..... 8
**2.6. Nạp dữ liệu mẫu** ..... 8
**CHƯƠNG 3: LUỒNG THAO TÁC** ..... **10**
**3.1. Luồng thao tác của quản trị viên** ..... 10
***3.1.1. Đăng nhập và đăng xuất*** ..... **10**
***3.1.2. Quản lý danh mục*** ..... **10**
***3.1.3. Quản lý sản phẩm*** ..... **11**
***3.1.4. Tổng quan và banner*** ..... **11**
**3.2. Luồng thao tác của khách hàng** ..... 12
***3.2.1. Đăng ký và kích hoạt tài khoản*** ..... **12**
***3.2.2. Xem sản phẩm, đăng nhập và cập nhật hồ sơ*** ..... **13**
**3.3. Luồng giỏ hàng, đặt hàng và duyệt đơn** ..... 13
**3.4. Luồng xử lý xác thực bên trong hệ thống** ..... 14
**CHƯƠNG 4: DANH SÁCH API** ..... **16**

**CHƯƠNG 5: KẾ HOẠCH VÀ TIẾN ĐỘ ..... 18**
**5.1. Các giai đoạn thực hiện** ..... 18
**5.2. Bảng theo dõi tiến độ** ..... 18
**5.3. Điểm còn thiếu cần xử lý** ..... 19
**5.4. Thứ tự công việc tiếp theo** ..... 20
**CHƯƠNG 6: QUY ƯỚC LÀM VIỆC ..... 21**
**6.1. Quy ước Git** ..... 21
**6.2. Quy ước bảo mật** ..... 21
**6.3. Cách thêm một chức năng mới** ..... 21
**TÀI LIỆU THAM KHẢO ..... 22**

# DANH MỤC TỪ VIẾT TẮT

**Bảng 0.1. Danh mục từ viết tắt**

| STT | Từ viết tắt | Từ đầy đủ tiếng Anh | Từ đầy đủ tiếng Việt |
|---|---|---|---|
| 1 | API | Application Programming Interface | Giao diện lập trình ứng dụng |
| 2 | CRUD | Create, Read, Update, Delete | Thêm, xem, sửa, xóa |
| 3 | JWT | JSON Web Token | Chuỗi định danh dùng để xác thực |
| 4 | MERN | MongoDB, Express, React, Node.js | Bộ công nghệ phát triển web dùng JavaScript |
| 5 | REST | Representational State Transfer | Kiểu thiết kế API qua giao thức HTTP |
| 6 | CLO | Course Learning Outcome | Chuẩn đầu ra của học phần |
| 7 | URI | Uniform Resource Identifier | Chuỗi định danh tài nguyên, ở đây là chuỗi kết nối cơ sở dữ liệu |

# CHƯƠNG 1: TỔNG QUAN ĐỒ ÁN

## 1.1. Mục tiêu và phạm vi

Đồ án xây dựng website bán kính mắt (Eyewear Shop) bằng bộ công nghệ MERN, thực hiện cho học phần Lập trình web nâng cao (mã 71ITSE41403, lớp 261_71ITSE41403_01) do ThS. Đặng Đình Hòa giảng dạy. Sinh viên thực hiện là Phan Nguyễn Ngọc Thọ, mã số sinh viên 2374802010483. Theo đề cương học phần [2], đồ án nhóm có thuyết trình chiếm 50% điểm môn, điểm đậu từ 5,0 và không có thi lần 2.

Dự án bám theo project mẫu Shopping Online của giảng viên [1], thay dữ liệu từ đồng hồ sang kính mắt. Sản phẩm kính có thêm các thuộc tính thương hiệu, loại gọng và chất liệu. Mã nguồn lưu tại kho https://github.com/thotapcode/eyewear-shop-mern.

## 1.2. Kiến trúc hệ thống

Hệ thống gồm một máy chủ API và hai ứng dụng giao diện chạy độc lập. Hai ứng dụng giao diện gọi API của máy chủ qua axios, yêu cầu bắt đầu bằng đường dẫn /api được chuyển tiếp tới cổng 3000 nhờ tệp src/setupProxy.js của mỗi client.

**Bảng 1.1. Các thành phần của hệ thống**

| Thành phần | Công nghệ | Cổng | Vai trò |
|---|---|---|---|
| server | Node.js, Express, Mongoose | 3000 | Cung cấp RESTful API, xác thực, gửi email |
| client-admin | React | 3001, đường dẫn /admin | Trang quản trị danh mục, sản phẩm, đơn hàng, khách hàng |
| client-customer | React | 3002 | Trang khách xem sản phẩm, giỏ hàng, đặt hàng |
| Cơ sở dữ liệu | MongoDB Atlas | Dịch vụ đám mây | Lưu admin, danh mục, sản phẩm, khách hàng, đơn hàng |

## 1.3. Công nghệ và thư viện sử dụng

**Bảng 1.2. Thư viện chính**

| Phần | Thư viện | Mục đích |
|---|---|---|
| server | express, body-parser | Dựng máy chủ và đọc dữ liệu gửi lên |

| Phần | Thư viện | Mục đích |
|---|---|---|
| server | mongoose | Kết nối và thao tác MongoDB |
| server | jsonwebtoken | Tạo và kiểm tra token đăng nhập |
| server | nodemailer | Gửi email kích hoạt tài khoản |
| server | dotenv, nodemon | Đọc cấu hình từ file .env, tự khởi động lại khi sửa code |
| client | react, react-router-dom | Dựng giao diện và điều hướng trang |
| client | axios | Gọi API |
| client | create-react-app | Công cụ tạo và build dự án React theo hướng dẫn của giảng viên |

## 1.4. Cấu trúc thư mục

**Bảng 1.3. Cấu trúc thư mục dự án**

| Đường dẫn | Nội dung |
|---|---|
| server/index.js | Điểm khởi động máy chủ, gắn các nhóm API, tạo tài khoản admin mặc định |
| server/api/admin.js | API của quản trị viên |
| server/api/customer.js | API của khách hàng |
| server/models/Models.js | Các lược đồ dữ liệu: Admin, Category, Product, Customer, Order |
| server/utils | MyConstants (cấu hình), MongooseUtil (kết nối), JwtUtil (token), PasswordUtil (băm mật khẩu), MailUtil (gửi email) |
| client-admin/src | api.js (axios kèm token), AuthContext.js (trạng thái đăng nhập), setupProxy.js (chuyển tiếp /api), components (Layout, UI gồm thông báo và hộp xác nhận, GlassesMark), pages (Login, Dashboard, Categories, Products, Banners, Orders, Customers), styles.css |
| client-customer/src | api.js, AuthContext.js, setupProxy.js (chuyển tiếp /api), CartContext.js (giỏ hàng), components (Layout, ProductCard, BannerSlider, QtyStepper, Field, AuthShell, Reveal, GlassesMark), pages (Home, ProductList, ProductDetail, Cart, Checkout, Orders, Login, Signup, Active, MyProfile), styles.css |

| Đường dẫn | Nội dung |
|---|---|
| server/seed | Dữ liệu mẫu để trình diễn: seed.js (nạp và xóa), data.json (danh mục, sản phẩm, banner kèm ảnh thật), photos.json (danh sách ảnh nguồn), make_data.py (tạo lại data.json từ Wikimedia Commons) |
| docs | Kế hoạch thực hiện và tài liệu bàn giao |

### 1.5. Định hướng thiết kế giao diện

Hai ứng dụng giao diện dùng chung một hệ thiết kế để trang khách và trang quản trị nhìn cùng một thương hiệu. Toàn bộ màu, cỡ chữ và bo góc được khai báo bằng biến CSS ở đầu tệp styles.css của từng ứng dụng, muốn đổi giao diện chỉ cần sửa các biến này.

**Bảng 1.4. Các lựa chọn thiết kế**

| Yếu tố | Lựa chọn | Ghi chú |
|---|---|---|
| Màu nhấn | Đỏ, một màu duy nhất | #D92B26 ở chế độ sáng, #FF4A43 ở chế độ tối |
| Màu nền | Xám trắng #F4F4F4 và đen #0B0B0C | Phong cách đen trắng thời trang, chế độ tối đảo ngược hai màu này |
| Phông chữ | Barlow Condensed cho tiêu đề, Be Vietnam Pro cho nội dung | Cả hai đều hỗ trợ tiếng Việt, cài qua gói @fontsource nên không tải từ máy chủ ngoài |
| Bo góc | Không bo, mọi góc vuông | Áp dụng cho nút, ô nhập, thẻ, ảnh và bảng |
| Biểu tượng | Phosphor Icons | Một bộ biểu tượng duy nhất |
| Chuyển động | Thư viện motion | Dùng khi vào trang, hiện dần khi cuộn và phản hồi thao tác; tự tắt khi hệ điều hành bật giảm chuyển động |
| Chế độ tối | Tự theo cài đặt hệ điều hành | Đã thử cả hai chế độ ở trang khách |
| Trạng thái | Khung chờ, trạng thái trống, thông báo lỗi ngay dưới ô nhập | Có ở danh sách, chi tiết, biểu mẫu và bảng quản trị |

# CHƯƠNG 2: HƯỚNG DẪN CÀI ĐẶT VÀ CHẠY

## 2.1. Yêu cầu môi trường

Máy cần cài Node.js (bản phát triển dùng phiên bản 24, các bản từ 18 trở lên đều phù hợp) và Git. Tài khoản GitHub cần được chủ kho mời làm cộng tác viên để có quyền đẩy mã. Chuỗi kết nối cơ sở dữ liệu và mật khẩu liên quan được gửi riêng, không đưa vào mã nguồn.

## 2.2. Lấy mã nguồn và cài thư viện

```
git clone https://github.com/thotapcode/eyewear-shop-mern.git
cd eyewear-shop-mern
cd server && npm install
cd ../client-admin && npm install
cd ../client-customer && npm install
```

## 2.3. Cấu hình file .env

Trong thư mục server, sao chép file .env.example thành .env rồi điền giá trị. File .env đã nằm trong .gitignore nên không được đưa lên GitHub, tuyệt đối không dán nội dung file này vào tin nhắn hay báo cáo.

**Bảng 2.1. Các biến trong file .env**

| Biến | Ý nghĩa | Ghi chú |
|---|---|---|
| PORT | Cổng chạy máy chủ | Để trống thì dùng 3000 |
| MONGODB_URI | Chuỗi kết nối MongoDB Atlas | Dạng mongodb+srv://tài-khoản:mật-khẩu@cluster0.xxxxx.mongodb.net/eyewear ?retryWrites=true&w=majority. Thay mật khẩu thật, không giữ dấu < >, và có tên cơ sở dữ liệu eyewear |
| JWT_SECRET | Khóa ký token đăng nhập | Một chuỗi dài bất kỳ |
| ADMIN_USERNAME | Tên đăng nhập admin | Mặc định admin |
| ADMIN_PASSWORD | Mật khẩu admin | Dùng để tạo tài khoản admin ở lần chạy đầu khi bảng admin còn trống; đổi biến này về sau không đổi mật khẩu đã tạo |
| EMAIL_USER, EMAIL_PASS | Tài khoản gửi email kích hoạt | Có thể để trống. Khi trống, liên kết kích hoạt được in ra cửa sổ chạy máy chủ |

| Biến | Ý nghĩa | Ghi chú |
|---|---|---|
| CLIENT_URL | Địa chỉ trang khách | Mặc định http://localhost:3002, dùng để tạo liên kết kích hoạt |

### 2.4. Chạy hệ thống

Mở ba cửa sổ terminal, mỗi cửa sổ chạy một lệnh:

```
cd server && npm run dev
cd client-admin && npm start
cd client-customer && npm start
```

Sau khi chạy, trang quản trị ở địa chỉ http://localhost:3001/admin, trang khách ở http://localhost:3002 và kiểm tra máy chủ ở http://localhost:3000/hello.

### 2.5. Kiểm tra máy chủ đã hoạt động

Cửa sổ chạy máy chủ phải hiện lần lượt các dòng Server listening on 3000 và Connected to MongoDB. Địa chỉ /hello trả về nội dung Hello from server!. Nếu không thấy dòng Connected to MongoDB, cần kiểm tra lại biến MONGODB_URI (mật khẩu, tên cơ sở dữ liệu) và mục IP Access List trong MongoDB Atlas. Hiện danh sách này đã cho phép mọi địa chỉ (0.0.0.0/0) nên máy ở mạng khác vẫn kết nối được. Việc chuyển tiếp /api dùng tệp setupProxy.js thay cho trường proxy trong package.json, vì trường proxy gây lỗi allowedHosts khi chạy npm start trên máy không nhận được địa chỉ mạng LAN.

### 2.6. Nạp dữ liệu mẫu

Để có sẵn dữ liệu trình diễn mà không phải nhập tay, chạy lệnh dưới đây trong thư mục server khi máy chủ đã cấu hình xong file .env. Dữ liệu mẫu gồm 4 danh mục, 30 sản phẩm có ảnh thật, 3 banner, 10 khách hàng và 19 đơn hàng với đủ ba trạng thái. Giá tính bằng đồng (VNĐ). Sản phẩm dùng tên hãng và mẫu có thật như Ray-Ban Wayfarer, Clubmaster, Aviator, Oakley Juliet, JINS, kèm gọng, hộp và kính lọc ánh sáng xanh. Giá và thông số là số liệu tham khảo theo thị trường để trình diễn, không phải bảng giá chính thức của hãng. Ảnh lấy từ Wikimedia Commons với giấy phép tự do và được ghi nguồn trong tệp docs/ANH_NGUON.md. Ảnh chụp đúng loại kính nhưng có thể không trùng màu hoặc cỡ với mô tả, nên khi nộp bài nếu có ảnh sản phẩm của chính cửa hàng thì thay ở trang quản trị.

```
npm run seed          # nạp dữ liệu mẫu, bỏ qua nếu đã nạp
```

```
npm run seed:reset    # xóa dữ liệu mẫu cũ rồi nạp lại
npm run seed:clean    # chỉ xóa dữ liệu mẫu
```

Mọi bản ghi do lệnh này tạo đều có đánh dấu riêng, nên lệnh xóa chỉ xóa đúng dữ liệu mẫu, dữ liệu thật nhập tay không bị ảnh hưởng. Danh mục trùng tên với danh mục đã có sẽ được dùng lại, không tạo thêm bản sao.

**Bảng 2.2. Tài khoản khách hàng mẫu (mật khẩu chung Demo12345)**

| Tên đăng nhập | Trạng thái | Dùng để thử |
|---|---|---|
| minhanh, quocbao, hongnhung, duchuy, ngoclan, thanhtung, khanhlinh, giahan | Đang hoạt động | Đăng nhập, xem đơn, đặt hàng |
| vankhoa | Chưa kích hoạt | Gửi lại email kích hoạt ở trang admin |
| maiphuong | Đã bị khóa | Mở khóa ở trang admin |

# CHƯƠNG 3: LUỒNG THAO TÁC

Chương này mô tả từng bước thao tác của người dùng và kết quả hệ thống phản hồi, để người nhận bàn giao nắm được luồng đi trước khi đọc mã. Các luồng của quản trị viên và khách hàng (xem sản phẩm, tài khoản) đã có giao diện và API, đã được thử trên trình duyệt với dữ liệu thật. Giỏ hàng, đặt hàng, duyệt đơn và quản lý khách hàng cũng đã có đủ giao diện và API.

## 3.1. Luồng thao tác của quản trị viên

### *3.1.1. Đăng nhập và đăng xuất*

**Bảng 3.1. Luồng đăng nhập và đăng xuất của quản trị viên**

| Bước | Thao tác | Phản hồi của hệ thống |
|---|---|---|
| 1 | Mở http://localhost:3001/admin | Nếu chưa đăng nhập, hệ thống chuyển sang trang đăng nhập |
| 2 | Nhập tên đăng nhập admin và mật khẩu ADMIN_PASSWORD, bấm Đăng nhập | Đúng thì vào trang Quản lý danh mục, token được lưu trong trình duyệt. Sai thì hiện thông báo lỗi màu đỏ |
| 3 | Tải lại trang khi đang đăng nhập | Hệ thống kiểm tra lại token, còn hợp lệ thì giữ nguyên phiên |
| 4 | Bấm Đăng xuất ở góc phải thanh menu | Token bị xóa, quay về trang đăng nhập |

### *3.1.2. Quản lý danh mục*

**Bảng 3.2. Luồng quản lý danh mục**

| Bước | Thao tác | Phản hồi của hệ thống |
|---|---|---|
| 1 | Bấm Danh mục trên thanh menu | Hiện ô nhập và bảng các danh mục hiện có |
| 2 | Nhập tên danh mục (ví dụ Kính cận) rồi bấm Thêm | Danh mục xuất hiện trong bảng, báo Đã thêm danh mục |
| 3 | Bấm Sửa ở một dòng | Tên được đưa lên ô nhập, nút đổi thành Cập nhật. Sửa tên rồi bấm Cập nhật để lưu, hoặc bấm Hủy để bỏ |
| 4 | Bấm Xóa ở một dòng | Hiện hộp xác nhận, đồng ý thì danh mục bị xóa khỏi bảng |

### *3.1.3. Quản lý sản phẩm*

Cần tạo danh mục trước vì mỗi sản phẩm phải thuộc một danh mục.

**Bảng 3.3. Luồng quản lý sản phẩm**

| Bước | Thao tác | Phản hồi của hệ thống |
|---|---|---|
| 1 | Bấm Sản phẩm ở thanh bên | Hiện bảng sản phẩm có ảnh nhỏ, cột tồn kho, mỗi trang tối đa 8 dòng. Gõ vào ô tìm kiếm để lọc theo tên hoặc thương hiệu |
| 2 | Bấm Thêm sản phẩm, nhập tên, giá, tồn kho, chọn danh mục, nhập thương hiệu, loại gọng, chất liệu và mô tả | Biểu mẫu mở ra, danh sách danh mục lấy từ cơ sở dữ liệu |
| 3 | Chọn tệp ảnh | Ảnh được đổi sang chuỗi base64 và hiện bản xem trước; ảnh trên 1,5 MB bị từ chối |
| 4 | Bấm Thêm sản phẩm trong biểu mẫu | Thiếu tên, giá hoặc danh mục thì báo lỗi ngay dưới ô tương ứng. Hợp lệ thì hiện thông báo thành công và sản phẩm xuất hiện ở trang đầu (sắp theo mới nhất) |
| 5 | Bấm số trang bên dưới bảng | Chuyển sang trang tương ứng |
| 6 | Bấm Sửa ở một dòng | Biểu mẫu được điền sẵn dữ liệu, trang cuộn lên đầu. Bấm Cập nhật để lưu |
| 7 | Bấm Xóa ở một dòng | Hiện hộp xác nhận, đồng ý thì xóa sản phẩm |

### *3.1.4. Tổng quan và banner*

**Bảng 3.2b. Luồng xem tổng quan và quản lý banner**

| Bước | Thao tác | Phản hồi của hệ thống |
|---|---|---|
| 1 | Đăng nhập hoặc bấm Tổng quan ở thanh bên | Hiện doanh thu từ đơn đã duyệt, số đơn chờ duyệt (đỏ khi có đơn chờ), số khách, số sản phẩm, 5 đơn mới nhất và các sản phẩm còn từ 5 cái trở xuống |

| Bước | Thao tác | Phản hồi của hệ thống |
|---|---|---|
| 2 | Bấm Banner ở thanh bên, rồi Thêm banner | Mở biểu mẫu gồm tiêu đề, dòng phụ, chữ trên nút, liên kết, thứ tự và ảnh |
| 3 | Chọn trang đích ở ô Chọn nhanh liên kết (trang chủ hoặc một danh mục), chọn ảnh ngang khoảng 1600 x 600, bấm Thêm banner | Banner xuất hiện trong bảng. Liên kết chỉ nhận đường dẫn nội bộ bắt đầu bằng / hoặc địa chỉ http |
| 4 | Bấm biểu tượng con mắt ở một dòng | Ẩn hoặc hiện banner trên trang chủ mà không cần tải lại ảnh |
| 5 | Bấm Sửa hoặc Xóa ở một dòng | Sửa trong biểu mẫu, hoặc xóa sau khi xác nhận |

## 3.2. Luồng thao tác của khách hàng

### *3.2.1. Đăng ký và kích hoạt tài khoản*

**Bảng 3.4. Luồng đăng ký và kích hoạt tài khoản khách hàng**

| Bước | Thao tác | Phản hồi của hệ thống |
|---|---|---|
| 1 | Điền tên đăng nhập, mật khẩu, họ tên, số điện thoại, email và gửi đăng ký | Máy chủ kiểm tra đủ thông tin và tên đăng nhập chưa tồn tại, băm mật khẩu rồi lưu tài khoản ở trạng thái chưa kích hoạt |
| 2 | Máy chủ gửi email chứa liên kết kích hoạt | Khi chưa cấu hình email, liên kết được in ra cửa sổ chạy máy chủ để người phát triển lấy dùng |
| 3 | Mở liên kết có dạng /active?id=...&token=... | Nếu mã đúng, tài khoản chuyển sang đã kích hoạt, nếu sai thì báo liên kết không hợp lệ |
| 4 | Thử đăng nhập khi chưa kích hoạt | Bị từ chối với thông báo tài khoản chưa được kích hoạt |

### *3.2.2. Xem sản phẩm, đăng nhập và cập nhật hồ sơ*

**Bảng 3.5. Luồng xem sản phẩm và quản lý hồ sơ của khách hàng**

| Bước | Thao tác | Phản hồi của hệ thống |
|---|---|---|
| 1 | Mở trang chủ | Hiện banner tự chuyển ảnh (dừng khi rê chuột), dải tên danh mục, 3 sản phẩm mới nhất, danh mục dạng chỉ mục và 3 sản phẩm bán chạy nhất (tính theo các đơn chưa bị hủy). Chưa có banner thì hiện phần giới thiệu mặc định |
| 2 | Chọn một danh mục | Hiện các sản phẩm thuộc danh mục |
| 3 | Nhập từ khóa vào ô tìm kiếm | Hiện sản phẩm có tên hoặc thương hiệu chứa từ khóa, không phân biệt hoa thường |
| 4 | Bấm vào một sản phẩm | Hiện trang chi tiết gồm ảnh, giá, danh mục, thương hiệu, loại gọng, chất liệu |
| 5 | Đăng nhập bằng tài khoản đã kích hoạt | Nhận token, lưu trong trình duyệt |
| 6 | Sửa họ tên, điện thoại, email hoặc mật khẩu ở trang hồ sơ | Chỉ sửa được hồ sơ của chính mình, thông tin mới được lưu |

## 3.3. Luồng giỏ hàng, đặt hàng và duyệt đơn

Luồng dưới đây theo yêu cầu buổi 9 của đề cương [2] và slide của giảng viên [1]. Giỏ hàng chỉ lưu mã sản phẩm và số lượng ở trình duyệt, khi đặt hàng máy chủ tự tính lại giá từ cơ sở dữ liệu nên khách không sửa được giá và trừ tồn kho ngay lúc đặt. Mỗi sản phẩm tối đa 20 cái mỗi đơn. Chỉ có hình thức thanh toán khi nhận hàng (COD).

**Bảng 3.6. Luồng giỏ hàng, đặt hàng và duyệt đơn**

| Bước | Người thao tác | Thao tác | Kết quả |
|---|---|---|---|
| 1 | Khách hàng | Bấm Thêm vào giỏ ở trang chi tiết sản phẩm | Sản phẩm vào giỏ, giỏ lưu ở phía trình duyệt |
| 2 | Khách hàng | Mở giỏ hàng, xóa bớt sản phẩm nếu cần | Giỏ cập nhật, hiện tổng tiền |

| Bước | Người thao tác | Thao tác | Kết quả |
|---|---|---|---|
| 3 | Khách hàng | Bấm Tiến hành thanh toán. Nếu chưa đăng nhập thì chuyển sang trang đăng nhập rồi quay lại | Mở trang Thanh toán, tên, số điện thoại và địa chỉ được điền sẵn từ hồ sơ |
| 3a | Khách hàng | Kiểm tra thông tin giao hàng, nhập ghi chú nếu cần, bấm Xác nhận đặt hàng | Thiếu hoặc sai thông tin thì báo lỗi dưới ô. Hợp lệ thì máy chủ trừ kho, tạo đơn trạng thái PENDING (Chờ duyệt), làm trống giỏ và chuyển sang trang đơn hàng. Không đủ hàng thì báo số còn lại và không trừ kho |
| 4 | Khách hàng | Mở mục Đơn hàng của tôi, bấm Hủy đơn rồi Xác nhận hủy khi đơn còn chờ duyệt | Xem các đơn cùng thông tin giao hàng và trạng thái. Hủy xong đơn chuyển sang Đã hủy và hàng được trả về kho |
| 5 | Quản trị viên | Mở danh sách đơn hàng | Thấy tất cả đơn của mọi khách |
| 6 | Quản trị viên | Bấm dấu duyệt hoặc dấu hủy ở một đơn đang chờ, rồi xác nhận | Trạng thái chuyển sang APPROVED hoặc CANCELED và không đổi lại được; hủy thì hàng được trả về kho; có thể lọc đơn theo trạng thái. Mỗi dòng đơn hiện kèm người nhận, số điện thoại và địa chỉ giao |
| 7 | Quản trị viên | Mở mục Khách hàng, khóa hoặc mở khóa tài khoản, gửi lại email kích hoạt, xem đơn của khách | Tài khoản bị khóa không đăng nhập và không đặt hàng được, kể cả khi còn token cũ |

### 3.4. Luồng xử lý xác thực bên trong hệ thống

Mỗi lần đăng nhập thành công, máy chủ tạo một token JWT có hiệu lực một giờ và ghi kèm vai trò (admin hoặc customer). Các API cần bảo vệ đi qua một lớp kiểm tra trước khi vào

xử lý. Việc ghi vai trò vào token giúp token của khách không dùng được cho API quản trị và ngược lại.

**Bảng 3.7. Các bước kiểm tra token ở máy chủ**

| Bước | Nội dung kiểm tra | Nếu không đạt |
|---|---|---|
| 1 | Yêu cầu có header x-access-token | Trả về success là false, thông báo chưa gửi token |
| 2 | Token đúng chữ ký và chưa hết hạn | Trả về success là false, thông báo token không hợp lệ |
| 3 | Vai trò trong token khớp nhóm API (admin hoặc customer) | Trả về success là false, thông báo token không hợp lệ |
| 4 | Với sửa hồ sơ khách, mã người dùng trong token trùng mã trong đường dẫn | Trả về success là false, thông báo không có quyền |

# CHƯƠNG 4: DANH SÁCH API

Mọi API trả về dữ liệu JSON. Các API ghi chú cần token phải gửi kèm header x-access-token. Dữ liệu gửi lên ở dạng JSON.

**Bảng 4.1. API của quản trị viên (tiền tố /api/admin)**

| Phương thức | Đường dẫn | Chức năng | Token |
|---|---|---|---|
| POST | /login | Đăng nhập, trả về token | Không |
| GET | /token | Kiểm tra token còn hợp lệ | Có |
| GET | /categories | Danh sách danh mục | Có |
| POST | /categories | Thêm danh mục | Có |
| PUT | /categories/:id | Sửa danh mục | Có |
| DELETE | /categories/:id | Xóa danh mục | Có |
| GET | /products?page=1&q= | Danh sách sản phẩm có phân trang và tìm kiếm | Có |
| POST | /products | Thêm sản phẩm | Có |
| PUT | /products/:id | Sửa sản phẩm | Có |
| DELETE | /products/:id | Xóa sản phẩm | Có |
| GET | /stats | Số liệu tổng quan: doanh thu, đơn, khách, sản phẩm sắp hết | Có |
| GET | /banners | Danh sách banner | Có |
| POST | /banners | Thêm banner | Có |
| PUT | /banners/:id | Sửa banner | Có |
| PUT | /banners/active/:id | Ẩn hoặc hiện banner | Có |
| DELETE | /banners/:id | Xóa banner | Có |
| GET | /orders | Danh sách tất cả đơn hàng | Có |
| GET | /orders/customer/:cid | Đơn hàng của một khách | Có |
| PUT | /orders/status/:id | Duyệt hoặc hủy đơn đang chờ | Có |
| GET | /customers | Danh sách khách hàng | Có |
| PUT | /customers/deactive/:id | Khóa tài khoản đang hoạt động | Có |
| PUT | /customers/reactive/:id | Mở khóa tài khoản đã khóa | Có |

| Phương thức | Đường dẫn | Chức năng | Token |
|---|---|---|---|
| GET | /customers/sendmail/:id | Gửi lại email kích hoạt | Có |

**Bảng 4.2. API của khách hàng (tiền tố /api/customer)**

| Phương thức | Đường dẫn | Chức năng | Token |
|---|---|---|---|
| GET | /categories | Danh sách danh mục | Không |
| GET | /banners | Banner đang hiển thị, theo thứ tự | Không |
| GET | /products/new | 3 sản phẩm mới nhất | Không |
| GET | /products/hot | 3 sản phẩm bán chạy nhất | Không |
| GET | /products/category/:id | Sản phẩm theo danh mục | Không |
| GET | /products/search/:keyword | Tìm sản phẩm theo tên hoặc thương hiệu | Không |
| GET | /products/:id | Chi tiết một sản phẩm | Không |
| POST | /signup | Đăng ký tài khoản | Không |
| POST | /active | Kích hoạt tài khoản bằng mã | Không |
| POST | /login | Đăng nhập, trả về token | Không |
| GET | /token | Kiểm tra token còn hợp lệ | Có |
| PUT | /customers/:id | Sửa hồ sơ của chính mình | Có |
| POST | /checkout | Đặt hàng từ giỏ kèm thông tin giao hàng | Có |
| GET | /orders/customer/:cid | Đơn hàng của chính mình | Có |
| PUT | /orders/cancel/:id | Hủy đơn đang chờ duyệt của chính mình | Có |

Tài khoản khách có ba trạng thái: 0 là chưa kích hoạt, 1 là đang hoạt động, 2 là bị khóa. Liên kết kích hoạt chỉ dùng được khi tài khoản ở trạng thái 0, nên tài khoản bị khóa không tự mở lại bằng liên kết cũ.

# CHƯƠNG 5: KẾ HOẠCH VÀ TIẾN ĐỘ

## 5.1. Các giai đoạn thực hiện

**Bảng 5.1. Giai đoạn thực hiện theo đề cương học phần**

| Giai đoạn | Nội dung | Tiêu chí chấm liên quan |
|---|---|---|
| 1. Khung dự án | Cấu trúc ba thư mục, kết nối cơ sở dữ liệu, token, băm mật khẩu | Công nghệ |
| 2. Quản trị viên | Đăng nhập, danh mục, sản phẩm | Chức năng, giao diện |
| 3. Khách hàng | Trang chủ, danh sách, tìm kiếm, chi tiết, đăng ký, kích hoạt, đăng nhập, hồ sơ | Chức năng, giao diện |
| 4. Giỏ hàng và đơn hàng | Giỏ, thanh toán, đơn của tôi, duyệt đơn, quản lý khách hàng | Chức năng |
| 5. Triển khai | Cấu hình máy chủ phục vụ bản build, đưa lên hosting | Công nghệ |
| 6. Hoàn thiện | Kiểm thử toàn bộ, báo cáo, slide thuyết trình | Thuyết trình |

## 5.2. Bảng theo dõi tiến độ

Cột Trạng thái dùng hai mức: Xong là đã có mã và đã kiểm tra; Chưa là chưa làm.

**Bảng 5.2. Tiến độ từng chức năng**

| STT | Chức năng | API | Giao diện | Trạng thái |
|---|---|---|---|---|
| 1 | Khung máy chủ, kết nối cơ sở dữ liệu | Có | Không áp dụng | Xong |
| 2 | Admin đăng nhập, đăng xuất | Có | Có | Xong |
| 3 | Admin quản lý danh mục | Có | Có | Xong |
| 4 | Admin quản lý sản phẩm | Có | Có | Xong |
| 5 | Khách: trang chủ | Có | Có | Xong |
| 6 | Khách: danh sách theo danh mục | Có | Có | Xong |
| 7 | Khách: tìm kiếm | Có | Có | Xong |
| 8 | Khách: chi tiết sản phẩm | Có | Có | Xong |
| 9 | Khách: đăng ký | Có | Có | Xong |
| 10 | Khách: kích hoạt tài khoản | Có | Có | Xong |

| STT | Chức năng | API | Giao diện | Trạng thái |
|---|---|---|---|---|
| 11 | Khách: đăng nhập, đăng xuất | Có | Có | Xong |
| 12 | Khách: hồ sơ cá nhân | Có | Có | Xong |
| 13 | Khách: giỏ hàng | Không cần | Có | Xong |
| 14 | Khách: đặt hàng | Có | Có | Xong |
| 15 | Khách: đơn hàng của tôi | Có | Có | Xong |
| 16 | Admin: danh sách và duyệt đơn | Có | Có | Xong |
| 17 | Admin: quản lý khách hàng | Có | Có | Xong |
| 18 | Thông tin giao hàng khi đặt hàng | Có | Có | Xong |
| 19 | Tồn kho và mô tả sản phẩm | Có | Có | Xong |
| 20 | Khách tự hủy đơn, hoàn kho | Có | Có | Xong |
| 21 | Admin: trang tổng quan, tìm kiếm sản phẩm | Có | Có | Xong |
| 22 | Banner trang chủ và trang quản lý banner | Có | Có | Xong |
| 23 | Dữ liệu mẫu (lệnh npm run seed) | Không áp dụng | Không áp dụng | Xong |
| 24 | Triển khai lên hosting | Chưa | Chưa | Chưa |
| 25 | Báo cáo và slide thuyết trình | Không áp dụng | Không áp dụng | Chưa |

### 5.3. Điểm còn thiếu cần xử lý

Đã xử lý ở bản này: cả hai client tự đăng xuất khi token hết hạn, không xóa được danh mục còn sản phẩm, máy chủ kiểm tra đầy đủ dữ liệu sản phẩm và danh mục. Các điểm còn lại: dự án chưa có kiểm thử tự động, việc kiểm tra API được làm bằng đoạn mã gọi trực tiếp. Thanh toán mới có hình thức nhận hàng rồi trả tiền, chưa có cổng thanh toán trực tuyến và chưa thông báo cho khách qua email khi đơn được duyệt. Chưa có chức năng quên mật khẩu vì cần gửi email. Ảnh sản phẩm lưu dạng base64 trong cơ sở dữ liệu, gói miễn phí chỉ có 512 MB nên cần hạn chế dung lượng ảnh. Sản phẩm tạo trước khi có tính năng tồn kho được máy chủ gán tồn kho mặc định là 10 lần khởi động đầu tiên.

Giao diện khách và giao diện quản trị đã được thử trên trình duyệt với dữ liệu thật: xem sản phẩm, tìm kiếm, giỏ hàng, thanh toán có thông tin giao hàng, hủy đơn, duyệt đơn, khóa khách hàng, trang tổng quan, tồn kho và tìm kiếm sản phẩm. Ảnh dùng khi thử là ảnh tạo sẵn, chưa thử với ảnh chụp thật nên cần kiểm tra thêm kích thước hiển thị.

### 5.4. Thứ tự công việc tiếp theo

Các chức năng theo đề cương đã hoàn thành. Việc còn lại là kiểm thử lại toàn bộ trên trình duyệt với ảnh sản phẩm thật, xử lý các điểm còn lại ở mục 5.3, rồi cấu hình triển khai lên hosting, nơi triển khai cần chọn lại vì slide của giảng viên dùng Replit và dịch vụ này có thể đã thay đổi cách hoạt động. Báo cáo và slide thuyết trình làm song song ở giai đoạn cuối.

# CHƯƠNG 6: QUY ƯỚC LÀM VIỆC

## 6.1. Quy ước Git

Nhánh làm việc là main. Mỗi chức năng làm xong thì tạo một commit riêng, thông điệp commit viết bằng tiếng Việt, nêu rõ việc đã làm. Commit dùng tên và email của chủ kho đã cấu hình trong kho cục bộ, không thêm dòng ghi đồng tác giả. Chỉ đẩy lên GitHub sau khi đã build hoặc chạy thử không lỗi.

```
git config user.name "Phan Nguyễn Ngọc Thọ"
git config user.email "<email GitHub của chủ kho>"
git add <tệp hoặc thư mục của chức năng>
git commit -m "Mô tả việc đã làm"
git push
```

## 6.2. Quy ước bảo mật

Không đưa file .env, mật khẩu cơ sở dữ liệu hay mật khẩu tài khoản GitHub vào mã nguồn, tin nhắn hoặc ảnh chụp màn hình. Nếu một mật khẩu đã bị lộ thì đổi mật khẩu đó và cập nhật lại biến tương ứng trong file .env. Mật khẩu của admin và khách đều được băm trước khi lưu, không lưu dạng chữ thường.

## 6.3. Cách thêm một chức năng mới

**Bảng 6.1. Thứ tự làm một chức năng**

| Bước | Việc cần làm | Nơi thực hiện |
|---|---|---|
| 1 | Thêm hoặc sửa lược đồ dữ liệu nếu cần | server/models/Models.js |
| 2 | Viết API và gắn vào nhóm admin hoặc customer | server/api |
| 3 | Thử API bằng Postman hoặc đoạn mã gọi trực tiếp, kiểm tra cả trường hợp lỗi | Trình công cụ gọi API |
| 4 | Viết trang giao diện và thêm đường dẫn | client-admin/src hoặc client-customer/src |
| 5 | Chạy npm run build ở thư mục client để chắc không lỗi | Terminal |
| 6 | Cập nhật bảng tiến độ rồi commit riêng | docs và Git |

# TÀI LIỆU THAM KHẢO

[1] Trang Hồng Sơn, "MERN stack - Shopping Online (bộ slide buổi 7 đến 10)", tài liệu lưu hành nội bộ, Trường Đại học Văn Lang, 2023.

[2] Đặng Đình Hòa, "Đề cương chi tiết học phần Lập trình web nâng cao (71ITSE41403)", Khoa Công nghệ thông tin, Trường Đại học Văn Lang, 06/09/2026.